

**ANALISIS DAN IMPLEMENTASI SISTEM MANAJEMEN
KEAMANAN INFORMASI (SMKI) BERDASARKAN ISO/IEC 27001
(Studi Kasus: Perusahaan Teknologi Tekno Cepat)**



Disusun Oleh:

Farhan Afiq Fauzan – 221011401133

**PROGRAM STUDI TEKNIK INFORMATIKA
FAKULTAS KOMPUTER
UNIVERSITAS PAMULANG**

2025

DAFTAR ISI

ANALISIS DAN IMPLEMENTASI SISTEM MANAJEMEN KEAMANAN INFORMASI (SMKI) BERDASARKAN ISO/IEC 27001 (Studi Kasus: Perusahaan Teknologi TeknoCepat).....	i
DAFTAR ISI.....	i
BAB I PENDAHULUAN.....	1
1.1 Tujuan Tugas.....	1
1.2 Latar Belakang ISO/IEC 27001	1
BAB II PEMILIHAN ORGANISASI (TAHAP 1)	2
2.1 Profil Singkat Organisasi	2
2.2 Penentuan Ruang Lingkup SMKI (Scope).....	2
2.3 Identifikasi Aset Informasi Utama	2
BAB III ANALISIS KONTEKS ORGANISASI (TAHAP 2)	3
3.1 Identifikasi Isu Internal dan Eksternal	3
3.2 Identifikasi Pihak Berkepentingan (Stakeholder)	3
BAB IV PENILAIAN RISIKO KEAMANAN INFORMASI (TAHAP 3).....	4
4.1 Metodologi Penilaian Risiko.....	4
4.2 Hasil Penilaian Risiko	4
BAB V PEMILIHAN DAN RANCANGAN KONTROL (TAHAP 4)	5
BAB VI RANCANGAN DOKUMEN UTAMA SMKI (TAHAP 5)	6
5.1 Kebijakan Keamanan Informasi.....	6
5.2 Tujuan Keamanan Informasi.....	6
5.3 Rencana Implementasi SMKI	6
BAB VII KESIMPULAN DAN REKOMENDASI (TAHAP 6)	7
6.1 Kesimpulan.....	7
6.2 Rekomendasi	7

BAB I

PENDAHULUAN

1.1 Tujuan Tugas

Tugas ini bertujuan untuk memberikan pengalaman simulasi bagi mahasiswa dalam menerapkan standar internasional ISO/IEC 27001 (terutama versi 2022) pada sebuah organisasi. Secara spesifik, tugas ini bertujuan agar mahasiswa mampu:

1. Memahami prinsip, struktur, dan tujuan standar ISO/IEC 27001.
2. Menganalisis kebutuhan organisasi terkait keamanan informasi.
3. Mengidentifikasi risiko keamanan informasi dan menyusun kontrol mitigasi awal.
4. Mendesain kerangka kerja awal Sistem Manajemen Keamanan Informasi (SMKI).

1.2 Latar Belakang ISO/IEC 27001

ISO/IEC 27001 adalah standar internasional untuk Sistem Manajemen Keamanan Informasi (SMKI). Standar ini menetapkan persyaratan untuk membangun, mengimplementasikan, memelihara, dan terus meningkatkan sistem manajemen keamanan informasi dalam konteks organisasi. Fokus utama dari standar ini adalah perlindungan terhadap kerahasiaan (Confidentiality), integritas (Integrity), dan ketersediaan (Availability) informasi melalui pendekatan manajemen risiko. Penerapan SMKI berbasis ISO/IEC 27001 bersifat esensial bagi organisasi modern untuk menjaga kepercayaan pelanggan, mematuhi regulasi, dan memastikan kelangsungan bisnis di tengah meningkatnya ancaman siber.

BAB II

PEMILIHAN ORGANISASI (TAHAP 1)

2.1 Profil Singkat Organisasi

Deskripsi Profil	Detail Simulasi
Nama Organisasi	Perusahaan Teknologi TeknoCepat
Jenis Bisnis	Perusahaan rintisan (startup) yang bergerak di bidang pengembangan aplikasi dan penyediaan layanan teknologi berbasis cloud.
Struktur Organisasi	Struktur ramping dipimpin oleh CEO, dengan dua divisi utama: CTO (membawahi Pengembangan dan Operasi TI) dan CMO (membawahi Marketing dan Penjualan).
Layanan Utama	Aplikasi kasir digital (Point of Sale/POS) berbasis cloud dan layanan manajemen inventori untuk Usaha Mikro, Kecil, dan Menengah (UMKM).

2.2 Penentuan Ruang Lingkup SMKI (Scope)

Ruang lingkup SMKI ini ditetapkan berdasarkan persyaratan Klausul 4.3 ISO/IEC 27001, dengan batasan yang jelas agar penerapan menjadi terfokus dan efektif:

Ruang Lingkup SMKI Perusahaan TeknoCepat:

"Sistem Manajemen Keamanan Informasi (SMKI) Perusahaan TeknoCepat mencakup seluruh proses bisnis dan sistem yang dikelola oleh Divisi Pengembangan Perangkat Lunak (Software Development) dan Divisi Operasi TI (meliputi infrastruktur cloud dan server produksi) yang mendukung layanan aplikasi POS dan manajemen inventori pelanggan. Ruang lingkup ini berlokasi di kantor pusat BSD Serpong."

2.3 Identifikasi Aset Informasi Utama

Identifikasi aset informasi adalah dasar untuk penilaian risiko. Aset utama dalam ruang lingkup yang ditetapkan adalah:

1. Data Transaksi Pelanggan: Data penjualan harian, inventori, dan informasi kontak pengguna akhir.
2. Kode Sumber Aplikasi (Source Code): Kode pemrograman untuk aplikasi POS dan sistem backend di Divisi Pengembangan.
3. Server Produksi: Infrastruktur fisik/virtual tempat aplikasi berjalan dan data pelanggan disimpan.
4. Data Pribadi Karyawan: Informasi pribadi, kontrak kerja, dan data gaji.

BAB III ANALISIS KONTEKS ORGANISASI (TAHAP 2)

3.1 Identifikasi Isu Internal dan Eksternal

Berdasarkan Klausul 4.1 ISO/IEC 27001, organisasi harus mempertimbangkan isu yang dapat memengaruhi pencapaian tujuan SMKI.

Jenis Isu	Deskripsi Isu (Contoh)	Implikasi Terhadap SMKI
Eksternal	Peningkatan Regulasi Data: Adanya Undang-Undang Perlindungan Data Pribadi (UU PDP) di Indonesia.	SMKI wajib memasukkan kontrol yang menjamin kepatuhan hukum, terutama terkait privasi.
Eksternal	Tren Serangan Ransomware: Peningkatan serangan siber yang menargetkan sektor startup dan cloud.	SMKI harus memperkuat kontrol teknis (A.8.16 Monitoring) dan kesiapan pemulihan bencana.
Internal	Kesadaran Karyawan Rendah: Karyawan sering menjadi korban serangan phishing atau lalai dalam penggunaan kata sandi.	Diperlukan peningkatan kontrol Manusia (People Controls) melalui pelatihan dan kesadaran (A.6.3).
Internal	Proses Pengembangan Cepat: Tekanan pasar membuat Divisi Pengembangan sering mengabaikan praktik secure coding demi kecepatan rilis.	SMKI harus mengintegrasikan kontrol keamanan ke dalam siklus pengembangan (DevSecOps - A.8.28).

3.2 Identifikasi Pihak Berkepentingan (Stakeholder)

Pihak berkepentingan (Klausul 4.2) adalah pihak yang kepentingannya memengaruhi atau dipengaruhi oleh SMKI.

Pihak Berkepentingan	Kebutuhan dan Harapan Terkait Keamanan Informasi
Pelanggan (UMKM)	Kerahasiaan dan Integritas data transaksi mereka (tidak boleh bocor atau dimanipulasi).
Manajemen Perusahaan	Ketersediaan layanan aplikasi (agar bisnis berjalan) dan kepatuhan regulasi (untuk menghindari denda).
Karyawan	Kejelasan kebijakan keamanan, pelatihan yang memadai, dan ketersediaan sistem yang stabil untuk bekerja.
Pemerintah/Regulator	Kepatuhan mutlak terhadap peraturan yang

BAB IV

PENILAIAN RISIKO KEAMANAN INFORMASI (TAHAP 3)

4.1 Metodologi Penilaian Risiko

Penilaian risiko dilakukan secara kualitatif dengan mempertimbangkan dua faktor utama:

1. Dampak (D): Tingkat keparahan kerugian jika risiko terjadi (Rendah, Sedang, Tinggi, Ekstrem).
2. Kemungkinan (K): Seberapa besar kemungkinan ancaman akan mengeksploitasi kerentanan (Rendah, Sedang, Tinggi).

Level Risiko ditentukan dengan matriks (misalnya: Tinggi x Tinggi = Ekstrem, Tinggi x Sedang = Tinggi, Sedang x Rendah = Rendah).

4.2 Hasil Penilaian Risiko

Aset	Ancaman	Kerentanan	Dampak (D)	Kemungkinan (K)	Level Risiko
Data Transaksi Pelanggan (di server)	Pencurian data/akses tidak sah.	Kontrol akses Least Privilege belum diterapkan.	Tinggi	Sedang	Tinggi
Server Produksi	Serangan Ransomware/Malware.	Patch Management dan Hardening konfigurasi tidak konsisten.	Tinggi	Tinggi	Ekstrem
Kode Sumber Aplikasi	Modifikasi tidak sah/injeksi malicious code.	Kurangnya code review dan kontrol versi yang ketat.	Sedang	Sedang	Sedang
Data Pribadi Karyawan	Kebocoran data akibat phishing.	Kurangnya pelatihan kesadaran keamanan.	Sedang	Tinggi	Tinggi

BAB V

PEMILIHAN DAN RANCANGAN KONTROL (TAHAP 4)

Berdasarkan hasil penilaian risiko pada Tahap 3, berikut adalah pemilihan minimal 10 kontrol keamanan dari **Annex A ISO/IEC 27001:2022** yang relevan untuk Perusahaan TeknoCepat:

No.	Kontrol Annex A (2022)	Alasan Pemilihan	Rencana Penerapan
1	A.5.1 Kebijakan Keamanan Informasi	Menjadi landasan hukum dan aturan main di seluruh organisasi.	Menyusun dokumen kebijakan utama yang ditandatangani oleh CEO.
2	A.5.15 Pengendalian Akses	Memitigasi risiko akses tidak sah ke data transaksi pelanggan.	Menerapkan autentikasi multifaktor (MFA) untuk semua akun admin.
3	A.5.17 Otentikasi Informasi	Menjamin bahwa hanya pengguna yang terverifikasi yang bisa mengakses sistem.	Implementasi sistem manajemen identitas (IAM) pada infrastruktur cloud.
4	A.6.3 Kesadaran & Pelatihan SMKI	Mengatasi masalah internal rendahnya kesadaran karyawan terhadap phishing.	Mengadakan pelatihan keamanan siber setiap 6 bulan sekali bagi seluruh staf.
5	A.7.4 Keamanan Fisik & Lingkungan	Melindungi aset di kantor pusat BSD Serpong dari akses fisik liar.	Melindungi aset di kantor pusat BSD Serpong dari akses fisik liar.
6	A.8.1 Perangkat Pengguna Akhir	Mengatur penggunaan laptop atau gawai yang digunakan karyawan untuk bekerja.	Implementasi kebijakan <i>Endpoint Detection and Response</i> (EDR) pada laptop staf.
7	A.8.16 Aktivitas Pemantauan	Deteksi dini terhadap serangan ransomware atau anomali jaringan.	Penggunaan sistem SIEM untuk memantau log server secara <i>real-time</i> .
8	A.8.20 Keamanan Jaringan	Melindungi aliran data antara aplikasi POS dan server cloud.	Penggunaan firewall (WAF) dan enkripsi SSL/TLS pada semua jalur komunikasi.
9	A.8.28 Pengodean Aman (<i>Secure Coding</i>)	Mencegah celah keamanan (seperti SQL Injection) sejak tahap pengembangan.	Integrasi pemindaian kode otomatis (SAST/DAST) dalam alur CI/CD.
10	A.8.32 Manajemen Perubahan	Memastikan setiap perubahan pada sistem tidak merusak stabilitas keamanan.	Prosedur persetujuan bertahap (Staging sebelum Production) oleh CTO.

BAB VI

RANCANGAN DOKUMEN UTAMA SMKI (TAHAP 5)

Sebagai bagian dari perancangan kerangka kerja SMKI, berikut adalah draf awal dokumen utama:

5.1 Kebijakan Keamanan Informasi

Tujuan: Menjamin kerahasiaan, integritas, dan ketersediaan aset informasi Perusahaan TeknoCepat. **Kebijakan:** 1. Seluruh karyawan wajib melindungi kerahasiaan data pelanggan. 2. Akses ke sistem produksi hanya diberikan berdasarkan prinsip *Need-to-Know*. 3. Setiap pelanggaran terhadap kebijakan ini akan dikenakan sanksi sesuai aturan perusahaan.

5.2 Tujuan Keamanan Informasi

1. Mencapai 100% ketersediaan layanan aplikasi POS selama jam operasional bisnis.
2. Mengurangi insiden kebocoran data akibat kesalahan manusia (human error) sebesar 80% dalam setahun.
3. Menyelesaikan perbaikan celah keamanan tingkat "Tinggi" maksimal 3 hari setelah ditemukan.

5.3 Rencana Implementasi SMKI

Fase	Aktivitas	Durasi Estimasi
Persiapan	Pembentukan Tim SMKI dan persetujuan anggaran.	Bulan 1
Perancangan	Penyusunan SoA (<i>Statement of Applicability</i>) dan Prosedur Kerja.	Bulan 2-3
Eksekusi	Instalasi alat keamanan dan pelatihan karyawan.	Bulan 4-6
Monitoring	Audit internal dan tinjauan manajemen.	Bulan 7

BAB VII

KESIMPULAN DAN REKOMENDASI (TAHAP 6)

6.1 Kesimpulan

Analisis ini menunjukkan bahwa Perusahaan TeknoCepat memiliki ketergantungan tinggi pada aset digital (Data Transaksi dan Source Code). Dengan menerapkan 10 kontrol utama dari Annex A ISO 27001:2022, perusahaan dapat menurunkan level risiko dari "Ekstrem" menjadi "Rendah/Sedang".

6.2 Rekomendasi

Untuk mencapai sertifikasi ISO 27001, organisasi disarankan untuk:

1. Segera melakukan *Gap Analysis* formal untuk membandingkan kondisi saat ini dengan standar ISO.
2. Memastikan komitmen penuh dari manajemen puncak (CEO/CTO) terkait ketersediaan sumber daya.
3. Melakukan simulasi audit internal sebelum mengundang badan sertifikasi eksternal.

DAFTAR PUSTAKA

- Darmawan, B. S., & Tarigan, A. (2018). Informasi Menggunakan Indeks Keamanan Informasi. *METIK Jurnal*, 2(1), 53–64.
- Mumtaz, A. (2024). *SEKOLAH TINGGI TEKNOLOGI TERPADU NURUL FIKRI Asesmen Risiko Keamanan Informasi Sistem Informasi Penerimaan Mahasiswa pada STT-NF dengan SNI ISO/ IEC 27001:2022 TUGAS AKHIR*.
- Sastra I Putu Narario. (2016). *Audit Keamanan Sistem Akuntansi Enterprise PT. Gresik Cipta Sejahtera Berdasarkan Standar ISO 27002:2005*. 5(8), 1–7.